

OWASP Top 10 for LLM Applications 2025

Clean Knowledge-Base Reference

Text-searchable reconstruction for the Safety Sentinel RAG prototype.

Important: this is not the original OWASP-branded publication. It is a concise, paraphrased reconstruction based on the official OWASP GenAI Security Project repository and web resources. It was created because the original PDF contains malformed internal font and stream structures that may render incorrectly.

Source organization: OWASP GenAI Security Project

Reference edition: 2025

Purpose and Structure

This reference summarizes the ten OWASP risk categories in a format designed for document chunking, semantic retrieval, source metadata, and citation validation.

Code	Risk
LLM01:2025	Prompt Injection
LLM02:2025	Sensitive Information Disclosure
LLM03:2025	Supply Chain
LLM04:2025	Data and Model Poisoning
LLM05:2025	Improper Output Handling
LLM06:2025	Excessive Agency
LLM07:2025	System Prompt Leakage
LLM08:2025	Vector and Embedding Weaknesses
LLM09:2025	Misinformation
LLM10:2025	Unbounded Consumption

Suggested citation marker: [OWASP-CLEAN-2025, LLMxx].

LLM01:2025 - Prompt Injection

Description

Instructions supplied directly by users or indirectly through external content can alter the intended behavior of an LLM application. Jailbreaking is a related technique aimed at bypassing safety restrictions.

Key risks

- Direct and indirect prompt injection
- System-instruction override
- Obfuscated or encoded attacks
- Manipulation of tool calls or retrieved context

Recommended controls

- Separate trusted instructions from untrusted content
- Validate input and output
- Use least privilege and human approval
- Perform regular adversarial testing

Relevance to Safety Sentinel

Supports the input guardrail, indirect-injection tests, and output validation.

Suggested source marker: [OWASP-CLEAN-2025, LLM01]

LLM02:2025 - Sensitive Information Disclosure

Description

An LLM application may expose personal data, credentials, confidential documents, proprietary information, or memorized training content through unsafe access patterns or generated responses.

Key risks

- PII and credential leakage
- Cross-user or cross-tenant disclosure
- Exposure of business or model information
- Privacy and intellectual-property violations

Recommended controls

- Minimize and sanitize data
- Apply least-privilege access
- Filter sensitive fields
- Keep secrets outside prompts and model context

Relevance to Safety Sentinel

Requires privacy-oriented Red Team prompts and response inspection.

Suggested source marker: [OWASP-CLEAN-2025, LLM02]

LLM03:2025 - Supply Chain

Description

Models, datasets, adapters, libraries, repositories, and deployment services form an AI supply chain. A compromised or unverified component can introduce vulnerabilities, malware, backdoors, bias, or licensing problems.

Key risks

- Vulnerable dependencies
- Tampered models or adapters
- Weak provenance
- Untrusted repositories and suppliers

Recommended controls

- Use verified sources and hashes
- Maintain SBOM/AI-BOM inventories
- Patch dependencies
- Red-team third-party models

Relevance to Safety Sentinel

Motivates provenance records and integrity hashes for every knowledge-base file.

Suggested source marker: [OWASP-CLEAN-2025, LLM03]

LLM04:2025 - Data and Model Poisoning

Description

Training, fine-tuning, embedding, or retrieval data can be manipulated to create bias, misinformation, hidden triggers, degraded behavior, or backdoors.

Key risks

- Poisoned RAG documents
- Biased or toxic outputs
- Hidden trigger behavior
- Compromised model files

Recommended controls

- Track data lineage and versions
- Accept only reviewed sources
- Use anomaly detection and sandboxing
- Monitor behavior and rebuild indexes through controlled processes

Relevance to Safety Sentinel

Applies directly to trusted-document selection and safe RAG ingestion.

Suggested source marker: [OWASP-CLEAN-2025, LLM04]

LLM05:2025 - Improper Output Handling

Description

Generated output must be treated as untrusted input. Passing it directly to browsers, shells, databases, templates, file systems, or tools can cause injection and code-execution vulnerabilities.

Key risks

- Unsafe HTML or JavaScript
- Generated shell or SQL execution
- Path traversal
- Downstream actions based on malicious output

Recommended controls

- Validate output for its destination
- Use encoding and schemas
- Use prepared statements and safe APIs
- Never execute model output directly

Relevance to Safety Sentinel

Defines the role of the output guardrail and safe response rendering.

Suggested source marker: [OWASP-CLEAN-2025, LLM05]

LLM06:2025 - Excessive Agency

Description

An LLM system becomes dangerous when it has more functions, permissions, or autonomy than required. Prompt injection or hallucination may then trigger damaging operations.

Key risks

- Excessive tool functionality
- Overprivileged service identities
- Autonomous high-impact actions
- Authorization delegated to the model

Recommended controls

- Minimize tools and permissions
- Use narrow purpose-built functions
- Execute in the user's security context
- Require approval for critical actions

Relevance to Safety Sentinel

The prototype should remain read-only and avoid unrestricted tool access.

Suggested source marker: [OWASP-CLEAN-2025, LLM06]

LLM07:2025 - System Prompt Leakage

Description

System prompts may be exposed and should not be considered secrets or security controls. The real risk occurs when prompts contain credentials, internal architecture, permissions, or sensitive policies.

Key risks

- Credential or architecture exposure
- Disclosure of filtering criteria
- Prompt secrecy used as a security boundary
- Sensitive role information in prompts

Recommended controls

- Never place secrets in prompts
- Enforce security in deterministic code
- Use external guardrails
- Separate privileges and responsibilities

Relevance to Safety Sentinel

Explains why system-prompt extraction tests are part of the Red Team dataset.

Suggested source marker: [OWASP-CLEAN-2025, LLM07]

LLM08:2025 - Vector and Embedding Weaknesses

Description

RAG systems can be compromised through weak access controls, poisoned documents, embedding leakage, cross-context retrieval, and conflicting or outdated information.

Key risks

- Unauthorized vector retrieval
- Knowledge-base poisoning
- Embedding inversion
- Cross-tenant information leakage

Recommended controls

- Use permission-aware vector stores
- Validate every indexed source
- Log retrieval activity
- Classify and partition documents

Relevance to Safety Sentinel

Central to document metadata, source validation, citation checking, and RAG security.

Suggested source marker: [OWASP-CLEAN-2025, LLM08]

LLM09:2025 - Misinformation

Description

LLMs can produce fluent but false or unsupported information. Hallucination, bias, incomplete data, and user overreliance can produce legal, operational, security, or reputational harm.

Key risks

- Fabricated facts and citations
- Unsupported claims
- Unsafe code suggestions
- Overreliance in high-stakes contexts

Recommended controls

- Use trusted RAG sources
- Validate claims and citations
- Communicate uncertainty
- Abstain when evidence is insufficient

Relevance to Safety Sentinel

This is the primary anti-hallucination objective of Safety Sentinel.

Suggested source marker: [OWASP-CLEAN-2025, LLM09]

LLM10:2025 - Unbounded Consumption

Description

Uncontrolled inference can exhaust compute, increase costs, degrade service, or support model extraction through repeated and resource-intensive queries.

Key risks

- Denial of service
- Denial of wallet
- Oversized inputs
- Model extraction through systematic querying

Recommended controls

- Set size and token limits
- Use rate limits, quotas, and timeouts
- Monitor anomalies and resource use
- Implement graceful degradation

Relevance to Safety Sentinel

Supports latency measurement, prompt-length limits, and API throttling.

Suggested source marker: [OWASP-CLEAN-2025, LLM10]

Official Sources and Attribution

The risk names and subject matter are derived from the official OWASP GenAI Security Project. The explanatory text in this document is paraphrased and reorganized for academic use and retrieval-augmented generation.

<https://genai.owasp.org/resource/owasp-top-10-for-llm-applications-2025/>

<https://github.com/OWASP/www-project-top-10-for-large-language-model-applications>

https://github.com/OWASP/www-project-top-10-for-large-language-model-applications/tree/main/2_0_vulns

The official repository states that the project is licensed under Creative Commons Attribution-ShareAlike 4.0 International. This reference attributes OWASP and is intended for compatible academic reuse.

RAG recommendation: split the document by LLM risk identifier and retain that identifier as metadata. Cite the identifier rather than relying only on page numbers.